



SECURITY ASSESSMENT

Vulnerability Report

Organized, deduplicated findings prepared for remediation.

GENERATED**2026-07-03 14:52****PROJECTS****FYP-test****SCOPE SUMMARY****Projects:** FYP-test • **Scan types:** Web • **Web URLs:** <https://juice-shop.herokuapp.com/> • **Severities:** All

OVERVIEW

Executive Summary

Duplicate names removed

AI-assisted analysis: rule-based risk scoring and priority assessment.

This assessment identified 25 unique vulnerabilities across 1 scan type (Web Application Scans) in FYP-test. The severity distribution includes 8 medium, 17 low severity findings. The overall risk posture is assessed as medium (score: 39.6/100). 8 medium-severity findings should be scheduled for remediation in the next planning cycle. Highest priority items: 'Cross-Domain Misconfiguration' (<https://juice-shop.herokuapp.com/>); 'Content Security Policy (CSP) Header Not Set' (<https://juice-shop.herokuapp.com/>).

TOTAL FINDINGS

25

Unique vulnerability names across all included scans.

RISK POSTURE

Medium Risk

Score: 39.6 | Confidence: medium

CRITICAL & HIGH

0 / 0

Medium: 8 | Low: 17



COVERAGE

Scan Coverage

Assets covered, recent activity, and severity distribution by scan type.

Scan Type	Assets Covered	Last Run	Critical	High	Medium	Low
Web Application Scans	1	2026-07-03 13:19	0	0	8	17

FOCUS

Priority Remediation Targets

Top assets by weighted risk to guide immediate remediation.

Rank	Scan Type	Target	Critical	High	Medium	Low	CVSS Ø	Risk Score	Priority
1	Web Application Scans	https://juice-shop.herokuapp.com/	0	0	8	17	3.1	39.6	Medium

Top Priority Items

- **Cross-Domain Misconfiguration** — https://juice-shop.herokuapp.com/ (score: 61.0, High)
- **Content Security Policy (CSP) Header Not Set** — https://juice-shop.herokuapp.com/ (score: 61.0, High)

FINDINGS

Detailed Findings

Every vulnerability name is deduplicated; descriptions, solutions, and references remain intact.

Web Application Scans

Runtime validation of application endpoints for injection flaws, session weaknesses, and misconfigurations.

Assets Covered	1						
Last Run	2026-07-03 13:19						
Most Impacted Targets	https://juice-shop.herokuapp.com/ Critical 0 High 0 Total 25						
URL	Status	Scan Type	Total	High	Medium	Low	Duplicates
	100		28	0	8	17	0

URL	Status	Scan Type	Total	High	Medium	Low	Duplicates
https://juice-shop.herokuapp.com/		Active + Passive + Spider + AJAX Spider					

FINDINGS DETAIL

Detailed Vulnerabilities (8)

Titles are deduplicated; supporting fields (solutions, references, notes) remain intact.

Unique vulnerability names

SEVERITY DISTRIBUTION

Severity	Findings	% Share
	2	25.0%
 Low	6	75.0%

DETECTION TREND

Not enough detection data to build a trend table.

SEVERITY

Medium Findings (2)**Medium**

Showing 2 unique vulnerabilities in this band.

Vulnerability	CVSS Score	CVSS Severity	Status	Risk
Cross-Domain Misconfiguration	5.5	Medium	Open	Medium
Content Security Policy (CSP) Header Not Set	5.5	Medium	Open	Medium

Cross-Domain Misconfiguration**Medium**

Ref: 45da3bf8-e546-4d83-acf7-06efa9f2d288

VULNERABILITY

Cross-Domain Misconfiguration

RISK

Medium

STATUS

Open

Description: Web browser data loading may be possible, due to a Cross Origin Resource Sharing (CORS) misconfiguration on the web server. CWE-264 <https://cwe.mitre.org/data/definitions/264.html> | WASC-14 | Confidence: Medium

Solutions: Ensure that sensitive data is not available in an unauthenticated manner (using IP address white-listing, for instance). Configure the "Access-Control-Allow-Origin" HTTP header to a more restrictive set of domains, or remove all CORS headers entirely, to allow the web browser to enforce the Same Origin Policy (SOP) in a more restrictive manner.

Reference: [https://vulnecat.fortify.com/en/detail?](https://vulnecat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy)

[category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy](https://vulnecat.fortify.com/en/detail?category=HTML5&subcategory=Overly%20Permissive%20CORS%20Policy)

- **Affected URL:** <https://juice-shop.herokuapp.com/>
- **Scanner:** Zap
- **Project:** FYP-test

Content Security Policy (CSP) Header Not Set

Medium Ref: 5b0cf1c7-c14c-4a07-a9e7-70235200d87b

VULNERABILITY

Content Security Policy (CSP) Header Not Set

RISK

Medium

STATUS

Open

Description: Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. CWE-693 <https://cwe.mitre.org/data/definitions/693.html> | WASC-15 | Confidence: High

Solutions: Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.

Reference: <https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP> https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html <https://www.w3.org/TR/CSP/> <https://w3c.github.io/webappsec-csp/> <https://web.dev/articles/csp> <https://caniuse.com/#feat=contentsecuritypolicy> <https://content-security-policy.com/>

- **Affected URL:** <https://juice-shop.herokuapp.com/>
- **Scanner:** Zap
- **Project:** FYP-test

SEVERITY

Low Findings (6)

Low

Showing 6 unique vulnerabilities in this band.

Vulnerability	CVSS Score	CVSS Severity	Status	Risk
Strict-Transport-Security Header Not Set	2.0	Low	Open	Low
Modern Web Application	2.0	Low	Open	Low
Timestamp Disclosure - Unix	2.0	Low	Open	Low
User Agent Fuzzer	2.0	Low	Open	Low
Re-examine Cache-control Directives	2.0	Low	Open	Low
HTTPS Content Available via HTTP	2.0	Low	Open	Low

Strict-Transport-Security Header Not Set

Low

Ref: ad62e842-36cd-4627-be4b-d5edd0bd68ee

VULNERABILITY

Strict-Transport-Security Header Not Set

RISK

Low

STATUS

Open

Description: HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797. CWE-319 <https://cwe.mitre.org/data/definitions/319.html> | WASC-15 | Confidence: High

Solutions: Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.

Reference: https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html <https://owasp.org/www-community/Security-Headers> https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security <https://caniuse.com/stricttransportsecurity> <https://datatracker.ietf.org/doc/html/rfc6797>

- **Affected URL:** <https://juice-shop.herokuapp.com/>
- **Scanner:** Zap
- **Project:** FYP-test

Modern Web Application

Low

Ref: cef48952-d550-45b8-8a08-63af37f07aa6

VULNERABILITY

Modern Web Application

RISK

Low

STATUS

Open

Description: The application appears to be a modern web application. If you need to explore it automatically then the Ajax Spider may well be more effective than the standard one. CWE--1 <https://cwe.mitre.org/data/definitions/-1.html> | WASC--1 | Confidence: Medium

Solutions: This is an informational alert and so no changes are required.

- **Affected URL:** <https://juice-shop.herokuapp.com/>
- **Scanner:** Zap
- **Project:** FYP-test

Timestamp Disclosure - Unix

Low

Ref: 29c828a8-11b2-444f-aa8c-c98a750b1eb0

VULNERABILITY

Timestamp Disclosure - Unix

RISK

Low

STATUS

Open

Description: A timestamp was disclosed by the application/web server. - Unix CWE-497 <https://cwe.mitre.org/data/definitions/497.html> | WASC-13 | Confidence: Low

Solutions: Manually confirm that the timestamp data is not sensitive, and that the data cannot be aggregated to disclose exploitable patterns.

Reference: <https://cwe.mitre.org/data/definitions/200.html>

- **Affected URL:** <https://juice-shop.herokuapp.com/>
- **Scanner:** Zap
- **Project:** FYP-test

User Agent Fuzzer

Low

Ref: 5a66a9ab-9355-499d-8d26-7fd44dee84a6

VULNERABILITY

User Agent Fuzzer

RISK

Low

STATUS

Open

Description: Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response. CWE-0 <https://cwe.mitre.org/data/definitions/0.html> | WASC-0 | Confidence: Medium

Reference: <https://owasp.org/wstg>

- **Affected URL:** <https://juice-shop.herokuapp.com/>
- **Scanner:** Zap
- **Project:** FYP-test

Re-examine Cache-control Directives

Low

Ref: 2e24c339-a311-4548-a6c8-c9966d0c044a

VULNERABILITY

Re-examine Cache-control Directives

RISK

Low

STATUS

Open

Description: The cache-control header has not been set properly or is missing, allowing the browser and proxies to cache content. For static assets like css, js, or image files this might be intended, however, the resources should be reviewed to ensure that no sensitive content will be cached. CWE-525 <https://cwe.mitre.org/data/definitions/525.html> | WASC-13 | Confidence: Low

Solutions: For secure content, ensure the cache-control HTTP header is set with "no-cache, no-store, must-revalidate". If an asset should be cached consider setting the directives "public, max-age, immutable".

Reference: [https://cheatsheetseries.owasp.org/cheatsheets/](https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching)

[Session_Management_Cheat_Sheet.html#web-content-caching https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control https://grayduck.mn/2021/09/13/cache-control-recommendations/](https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cache-Control)

- **Affected URL:** <https://juice-shop.herokuapp.com/>

- **Scanner:** Zap
- **Project:** FYP-test

HTTPS Content Available via HTTP

Low

Ref: c89754cc-0b13-40f4-8910-a770ccd41957

VULNERABILITY

HTTPS Content Available via HTTP

RISK

Low

STATUS

Open

Description: Content which was initially accessed via HTTPS (i.e.: using SSL/TLS encryption) is also accessible via HTTP (without encryption).

Solutions: Ensure that your web server, application server, load balancer, etc. is configured to only serve such content via HTTPS. Consider implementing HTTP Strict Transport Security.

- **Affected URL:** <https://juice-shop.herokuapp.com/>
- **Scanner:** Zap
- **Project:** FYP-test

Duplicate content noted:

- **Reference:** matches Low Strict-Transport-Security Header Not Set

(c) 2026 ArcherySec - Confidential Security Report